Transcript in English

IBM Technology. Risk Analysis - Know Your Threat Tolerance

[Visual information: The speaker is addressing the camera on a medium shot, standing against a black background. The video incorporates simple illustrations that are superimposed on the image of the speaker through a transparent filter and pop up on the screen as he mentions each new idea.]

«Jeff Crume, Distinguished Engineer. IBM Security»

Jeff Crume:
Hi, I'm Jeff Crume. I'm an IBM distinguished engineer. In a previous video, I talked to you about zero trust, and I concluded with the notion that risk analysis should inform our zero trust decisions. So to extend that, let's think about a thought question. Why do you put brakes on a car? Seems like an obvious enough question. Everyone says, "So you can stop." Let me suggest to you it's so that you can go really fast. And if you don't believe me, then think about how fast you'd be willing to drive a car that had no brakes. The answer is you wouldn't, you wouldn't even get in the thing.

So what the brakes do for us? They allow us to take calculated risk as opposed to a wild, uncalculated risk. So they're the things that allow us to control our risk. Now let's think about that and apply that to organisations and individuals and how we perceive risk.

For instance, some people, when it comes to travel, will say, "You know what? I don't like getting in aeroplanes. I'm going to take a train everywhere I go. If it takes me four days to get from Chicago to San Diego and four days back, that's what I want to do because that's my tolerance for risk."

[Visual information: The drawing of a train is shown on the screen to the left of the speaker.]

Someone else like me doesn't mind flying four million miles in the air. Okay, so I'm willing to get in the plane, but what I won't do and where I draw the line is getting out of the plane before it's on the ground. In that case, I'm going to say, I'm in the middle on the risk tolerance.

[Visual information: The drawing of a plane is shown on the screen to the left of the speaker.]

But then some people are willing to say, "You know what? With a parachute, I can get out of this perfectly good aeroplane and I don't have to wait for it to come down to the ground."

[Visual information: The drawing of a parachute is shown on the screen to the left of the speaker.]

Three different tolerances for risk, three different risk profiles. Now, what does that have to do with this subject? Well, organisations are the same way: you could take a bank and it might be very risk-averse, or another bank in the same industry might be much more tolerant to risk.

So when we're making our security decisions, we have to consider what our tolerance for risk is to begin with. So to illustrate that, what would it look like as an example? Well, if we have, for instance, here [on the transparent screen] is a user who is going to hit our web server and a more risk-tolerant organisation might say, "I'm going to put a firewall in front so that I have some level of protection." Good enough, job done.

[Visual information: The speaker draws a smiley face representing a user under the parachute drawing. Next to the user he draws the icon of a web server. Between them, he draws a punctuated line representing a firewall.]

Now, another organisation might look at the very same set of issues, the things that we're trying to do, and might say, "No, I'd like a little more protection. I'm going to put my web server here, but I'm going to make a separation between the web server and the data –the database–, in particular, so that I can add another layer of security, another firewall, a second firewall. So that now if there's a bad guy trying to get in, he has to traverse two security zones in order to get there." More protection, more averse to risk.

[Visual information: The speaker draws a smiley face representing a user under the plane drawing. Next to the user he draws the icon of a web server. Between them, he draws a punctuated line representing a firewall. Then, to the right of the web server he draws an icon representing the data. Between the web server and the data he draws a punctuated line representing a second firewall.]

However, some organisations like the train guy are going to look at this even more risk-averse, and they're going to say, "What I want to do is even more separation. I'll put my web server here, an application server behind it, and separate the data from the application." So now I have a path that looks like this. Now I have a traditional DMZ for the web server that's just the presentation services. The application itself is protected from the web server and the data is separated from all of it.

[Visual information: The speaker draws a smiley face representing a user under the train drawing. Next to the user he draws the icon of a web server. Between them, he draws a punctuated line representing a firewall. Then, to the right of the web server, he draws an icon representing an application server. Between the web server and the application he draws a punctuated line representing a second firewall. Finally, to the right of the application he draws an icon representing the data. Between the application and the data he draws a punctuated line representing a third firewall.]

So which one of these is the right answer? Well, it all depends. It depends on a lot of things. It depends on your tolerance for risk, your organisation's tolerance. Is your organisation a train, a plane or a parachute? It also depends on cost. If this is too expensive [train drawing], or the type of data that I'm trying to protect isn't worth that level of protection, then I would scale back to one of these others [plane or parachute drawing].

So there are a lot of considerations that go into this. And if you want more help, we have some resources linked down below where you can see IBM can help in guiding these decisions. Thanks for watching. Please remember to like this video and subscribe to this channel so we can continue to bring you content that matters to you.